administration tasks to run without leaving a highly privileged account enabled at all times.

- Fine-grained access controls can be applied, ensuring that services only have access to the credentials they need.
- All access to secrets can be logged, leaving an audit trail. This can help to establish what happened after a breach, and automated systems can analyse these logs and alert if unusual access requests are noticed.

When the credentials being accessed are cryptographic keys, a *key management service* (KMS) can be used. A KMS, such as those provided by the main cloud providers, securely stores cryptographic key material. Rather than exposing that key material directly, a client of a KMS sends cryptographic operations to the KMS; for example, requesting that a message is signed with a given key. This ensures that sensitive keys are never directly exposed, and allows a security team to centralize cryptographic services, ensuring that all applications use approved algorithms.

> **DEFINITION** A ***key management service (KMS)*** stores keys on behalf of applications. Clients send requests to perform cryptographic operations to the KMS rather than asking for the key material itself. This ensures that sensitive keys never leave the KMS.

To reduce the overhead of calling a KMS to encrypt or decrypt large volumes of data a technique known as *envelope encryption* can be used. The application generates a random AES key and uses that to encrypt the data locally. The local AES key is known as a *data encryption key* (DEK).